

Évaluation de Cybersécurité

Maël MIGNARD

BTS SIO 1ère année

14 janvier 2026

1 Évaluation 1 : Skiloisir

1.1 Vulnérabilités organisationnelles et technologiques

- **Organisationnelles :**
 - Les données personnelles (nom, prénom, adresse, téléphone) sont conservées pendant 10 ans, ce qui est excessif et potentiellement non conforme au RGPD qui prône la minimisation de la durée de conservation.
 - La consultation des réservations se fait depuis un simple ordinateur "Windows 10", sans précision sur des mesures de sécurité spécifiques (antivirus, pare-feu local, etc.).
 - Il n'y a pas de politique de mot de passe robuste mentionnée pour l'accès à la base de données des réservations.
- **Technologiques :**
 - Le site web utilise le protocole HTTP et non HTTPS (Document 2). Le transfert des données d'inscription n'est donc pas chiffré.
 - L'architecture réseau montre une connexion directe entre le serveur web/base de données et Internet, bien que derrière un pare-feu. La mutualisation du serveur web et de la base de données sur la même machine (Ferme de serveurs) augmente la surface d'attaque.
 - Il n'est pas fait mention d'authentification multifacteur (MFA/2FA) pour l'accès aux données des clients, que ce soit pour les employés ou les administrateurs (Document 5).

1.2 Protocole de transfert non sécurisé

Le Document 3 explique clairement la différence entre HTTP et HTTPS. Le protocole HTTP utilisé par le site de Skiloisir (visible dans l'URL du Document 2 : <http://skiloisir.com>) ne répond pas aux critères de sécurité pour les raisons suivantes :

- **Confidentialité :** Les données circulent en clair sur le réseau. Un attaquant en position d'écoute (Man-in-the-Middle) peut intercepter et lire toutes les informations envoyées par le client lors de son inscription (nom, prénom, adresse, etc.).
- **Intégrité :** Rien ne garantit que les données envoyées par le client n'ont pas été altérées pendant leur transport. Un attaquant pourrait modifier les informations avant qu'elles n'atteignent le serveur.
- **Authentification :** Le client n'a aucune garantie de l'identité du serveur auquel il se connecte. Il pourrait être redirigé vers un site de phishing qui imite parfaitement le site de Skiloisir et ainsi voler ses identifiants.

1.3 Niveau de risque

Le Document 4 (Cartographie des risques) place le "Traitement des réservations" dans la catégorie Inacceptable (couleur rouge). Ce niveau de risque est la combinaison d'une vraisemblance élevée (probablement 3 ou 4) et d'une gravité élevée (probablement 3 ou 4).

Ce diagnostic est justifié car :

- La vraisemblance d'une attaque est forte. L'utilisation du protocole HTTP pour la collecte de données personnelles est une vulnérabilité bien connue et facilement exploitable par des outils automatisés.
- La gravité est également élevée. La fuite de données personnelles peut entraîner un préjudice pour les clients (usurpation d'identité, spam, etc.) et des sanctions sévères pour l'entreprise (amendes RGPD, perte de confiance, atteinte à l'image de marque).

Le risque est donc critique et nécessite une action immédiate.

2.1 Non-conformités RGPD

Plusieurs éléments sont non-conformes au RGPD :

- *Article 5.1.e (Limitation de la conservation)* : Les données sont conservées 10 ans, ce qui est une durée excessive pour des réservations de matériel de ski. La durée de conservation doit être limitée à ce qui est strictement nécessaire au regard de la finalité.
- *Article 5.1.f (Intégrité et confidentialité)* : L'utilisation du protocole HTTP pour la collecte des données ne garantit pas la sécurité des données, ce qui est une violation de l'obligation de "sécurité appropriée".
- *Article 25 (Protection des données dès la conception et par défaut)* : Le système n'a pas été conçu avec des mesures de sécurité robustes par défaut (HTTPS, mots de passe forts, etc.).
- *Article 32 (Sécurité du traitement)* : L'absence de chiffrement des données en transit et le manque de détails sur la sécurisation des postes de travail et des serveurs indiquent une défaillance dans la mise en œuvre de mesures techniques et organisationnelles appropriées.

2.2 Note de solutions techniques et organisationnelles

À : Direction de Skiloisir

De : Mael MIGNARD, Consultant Sécurité - Sécuinfo73

Objet : Solutions pour la mise en conformité du traitement des réservations

Madame, Monsieur,

Suite à notre audit, voici une liste de solutions techniques et organisationnelles pour mettre en conformité la gestion des réservations de matériel avec le RGPD.

Solutions Techniques :

1. **Mise en place du HTTPS** : Obtenir et installer un certificat SSL/TLS sur le serveur web pour chiffrer toutes les communications entre les clients et le site `skiloisir.com`. Cela garantira la confidentialité et l'intégrité des données transmises.

2. **Renforcement de l'authentification** : Mettre en place une authentification multifacteur (MFA), comme suggéré par l'ANSSI (Document 5), pour tous les accès à la base de données clients (par exemple, via une clé FIDO - Document 6, ou une application de validation).
3. **Séparation des serveurs** : Isoler le serveur web du serveur de base de données dans des zones réseau distinctes pour limiter la surface d'attaque en cas de compromission du serveur web.
4. **Sécurisation des postes de travail** : Déployer une politique de sécurité sur les postes de travail des employés (antivirus, pare-feu, mises à jour régulières, session qui se verrouille après une courte période d'inactivité).

Solutions Organisationnelles :

1. **Politique de conservation des données** : Réduire la durée de conservation des données clients à une période justifiée (par exemple, 3 ans après la dernière réservation, conformément aux recommandations de la CNIL pour les clients inactifs).
2. **Politique de mots de passe robustes** : Imposer des mots de passe complexes (longueur, variété des caractères) et un renouvellement régulier pour l'accès à tous les systèmes internes.
3. **Sensibilisation et formation** : Former les employés aux bonnes pratiques de sécurité et à l'importance de la protection des données personnelles.
4. **Registre des traitements** : Tenir à jour un registre des activités de traitement, comme l'exige le RGPD, en y documentant précisément la finalité, les catégories de données, les durées de conservation et les mesures de sécurité.

Ces mesures permettront de réduire significativement le niveau de risque et de garantir la conformité de Skiloisir avec la législation en vigueur.

Cordialement,

2 Évaluation 2 : 3 Garçons Gourmands

1.1 Éléments caractéristiques de l'hameçonnage

Le coupon de réduction (Document 1) présente plusieurs signes d'une opération d'hameçonnage :

- *Offre trop belle pour être vraie* : "le 2e menu identique gratuit" et un "Burger du chef" offert sont des appâts typiques de l'ingénierie sociale (Document 3) pour attirer les victimes.
- *Caractère d'urgence* : La mention "Offre valable jusqu'au 7 avril" crée un sentiment d'urgence pour pousser les utilisateurs à agir rapidement sans réfléchir.
- *URL suspecte* : Le lien vers le questionnaire est 50e-RESTAURANT-3-GARCONS-GOURMANDS.COM. Ce nom de domaine est différent du site officiel (www.3.garcons.gourmands.com mentionné sur la page Facebook), ce qui est un indicateur clé d'usurpation d'identité (Document 6).
- *Manque de mentions légales* : Le coupon ne respecte pas les obligations légales (Document 4), comme le nom et le RCS de l'émetteur ou le montant de la réduction en euros.

1.2 Stratégie pour obtenir les données personnelles

La stratégie des attaquants est un classique de l'hameçonnage en plusieurs étapes :

1. **Appât** : Diffusion d'une offre alléchante sur un réseau social (Facebook) pour atteindre un large public.
2. **Ingénierie sociale** : Le message demande de "partager ce post" (Document 2). Cela augmente la portée de l'attaque de manière virale, en utilisant la crédibilité des amis de la victime.
3. **Redirection vers un site malveillant** : Le lien fourni redirige vers un site contrôlé par les attaquants, imitant l'identité visuelle de "3 Garçons Gourmands".
4. **Collecte de données** : Le questionnaire (Document 2, "entrez vos coordonnées") est le moyen de collecte des données personnelles (probablement nom, email, téléphone, etc.). C'est une collecte frauduleuse au sens de l'article 226-18 du Code pénal (Document 7).

1.3 Conséquences pour l'entreprise

Les conséquences pour "3 Garçons Gourmands" sont multiples et graves :

- **Perte de confiance des clients** : Les clients qui se voient refuser le faux coupon au restaurant (Document 5, "#FauxCoupon") se sentent trompés. La publication d'avis négatifs ("C'est quoi cette arnaque?") nuit directement à l'image de l'enseigne.
- **Atteinte à l'image de marque** : L'association du nom de l'entreprise à une "arnaque" sur les réseaux sociaux peut rapidement devenir virale et détruire la réputation de la marque, qui est basée sur la qualité et la confiance.
- **Risques juridiques et financiers** :
 - L'entreprise est victime d'une usurpation d'identité (art. 226-4-1 du Code pénal, Document 7). Elle doit engager des frais pour se défendre et communiquer.
 - Le coût d'une cyberattaque, même indirecte, peut être élevé (Document 8), incluant la perte de revenus, les coûts de communication de crise, et les actions juridiques.

2.1 Éléments pour établir l'usurpation d'identité

Les éléments suivants, diffusés sur Facebook, permettent d'établir l'usurpation d'identité :

- **Usage de la charte graphique** : Le faux coupon (Document 1) utilise le logo et le nom "3 Garçons Gourmands", ce qui constitue une contrefaçon.
- **Nom de la page Facebook** : La publication est faite sous le nom "3 Garçons Gourmands" avec l'identifiant @3garçons_gourmands, qui est très proche de l'officiel, prtant confusion.
- **Lien vers le site officiel** : Ironiquement, la fausse publication inclut l'URL du vrai site web (www.3.garcons.gourmands.com) pour paraître plus crédible, tout en redirigeant vers un autre site pour le questionnaire.

2.2 Preuve de l'usurpation dans les URLs

L'usurpation d'identité est confirmée par l'analyse des URLs (Document 6) :

- **URL de contact (légitime)** : www.3.garcons.gourmands.com. Ici, "gourmands" est le composant principal (SLD) et ".com" est le TLD. Le nom de domaine appartient à l'entreprise.
- **URL du lien fourni (frauduleuse)** : 50e-RESTAURANT-3-GARCONS-GOURMANDS.COM. Dans ce cas, le nom de domaine est l'ensemble de la chaîne de caractères. Le TLD est ".COM", et le SLD est "50e-RESTAURANT-3-GARCONS-GOURMANDS". C'est un nom de domaine complètement différent, enregistré par un tiers pour tromper les utilisateurs.

La différence entre ces deux noms de domaine est la preuve technique irréfutable de l'usurpation d'identité.

2.3 Note sur la conduite à tenir

À : Mme Magnaval, RSSI

De : Mael MIGNARD, Assistant RSSI

Objet : Conduite à tenir suite à l'usurpation d'identité sur les réseaux sociaux

Chère Madame Magnaval,

Suite à l'attaque par hameçonnage visant notre entreprise, voici la procédure à suivre, conformément aux recommandations de la CNIL (Document 9).

Actions immédiates :

1. Constitution d'un dossier de preuves :

- Réaliser des captures d'écran de la publication Facebook, du faux coupon, et des commentaires négatifs.
- Relever les URLs exactes de la page frauduleuse et du questionnaire.
- Conserver tous les témoignages de clients ou employés.

2. Signalement et demande de suppression :

- Contacter immédiatement le support de Facebook pour signaler la page et la publication pour usurpation d'identité et demander leur suppression.
- Contacter l'hébergeur du nom de domaine frauduleux pour demander sa désactivation.

Actions légales :

- 1. Dépôt de plainte :** Déposer plainte auprès de la police ou de la gendarmerie pour usurpation d'identité (délit pénal selon l'art. 226-4-1 du Code pénal). Le dossier de preuves sera essentiel.

Communication :

- 1. Communication officielle :** Publier un démenti sur notre site web officiel et nos réseaux sociaux pour informer nos clients de la situation, les avertir de ne pas cliquer sur le lien et présenter nos excuses pour la confusion.
- 2. Monitoring :** Mettre en place une veille sur les réseaux sociaux pour suivre l'évolution de la situation et répondre aux préoccupations des clients.

Ces actions permettront de contenir l'attaque, de défendre les intérêts de l'entreprise et de rassurer notre clientèle.

Cordialement,